

Matriz de evaluación PRAGMATIC completa para indicadores CVSS v4.0

1. Escala de valoración

Se utiliza una escala 0–5 para cada criterio PRAGMATIC:

- 0: No aplica / sin valor.
- 1: Muy bajo.
- 2: Bajo.
- 3: Medio.
- 4: Alto.
- 5: Muy alto.

La puntuación global PRAGMATIC de cada métrica es la suma simple (máximo 45) o una media ponderada si se asignan pesos distintos a los criterios. [web:21][web:24][web:27]

2. Indicadores considerados

Tomamos como ejemplo cinco indicadores CVSS v4.0 de ámbito nacional:

1.

M1 – Densidad de vulnerabilidades críticas expuestas

Porcentaje de sistemas/servicios expuestos a Internet con vulnerabilidades CVSS Base ≥ 8.0 .
[web:1][web:16][web:22]

2.

M2 – Tiempo medio de mitigación de vulnerabilidades explotadas activamente

Promedio de días desde divulgación hasta mitigación para vulnerabilidades con métrica Threat = Active o Mass. [web:1][web:7][web:13]

3.

M3 – Proporción de vulnerabilidades críticas en servicios esenciales sin mitigación en plazo

Porcentaje de vulnerabilidades con Environmental que refleje alta criticidad (p. ej. disponibilidad alta) que superan el plazo objetivo de mitigación. [web:1][web:10][web:12]

4.

M4 – Índice de cobertura de evaluación CVSS v4.0

Porcentaje de vulnerabilidades relevantes para el país que cuentan con scoring completo (Base + Threat + Environmental) conforme a v4.0. [web:1][web:16][web:22]

5.

M5 – Índice de alineamiento regulatorio NIS2–CVSS

Proporción de incidentes notificados bajo NIS2 cuya gravedad y priorización está trazada a métricas CVSS de forma explícita. [web:7][web:13]

M1 – Densidad de vulnerabilidades críticas expuestas

Porcentaje de sistemas/servicios expuestos a Internet con vulnerabilidades CVSS Base ≥ 8.0 . [web:1][web:16][web:22]

M2 – Tiempo medio de mitigación de vulnerabilidades explotadas activamente

Promedio de días desde divulgación hasta mitigación para vulnerabilidades con métrica Threat = Active o Mass. [web:1][web:7][web:13]

M3 – Proporción de vulnerabilidades críticas en servicios esenciales sin mitigación en plazo

Porcentaje de vulnerabilidades con Environmental que refleje alta criticidad (p. ej. disponibilidad alta) que superan el plazo objetivo de mitigación. [web:1][web:10][web:12]

M4 – Índice de cobertura de evaluación CVSS v4.0

Porcentaje de vulnerabilidades relevantes para el país que cuentan con scoring completo (Base + Threat + Environmental) conforme a v4.0. [web:1][web:16][web:22]

M5 – Índice de alineamiento regulatorio NIS2–CVSS

Proporción de incidentes notificados bajo NIS2 cuya gravedad y priorización está trazada a métricas CVSS de forma explícita. [web:7][web:13]

3. Matriz PRAGMATIC (ejemplo cuantificado)

Métrica	Predictivo	Relevante	Accionable	Genuino	Significativo	Preciso	Oportuno	Independiente	Rentable	Total (0–45)
M1	3	4	4	3	4	3	4	3	4	32
M2	5	5	5	4	4	3	3	4	3	36
M3	5	5	5	4	5	3	3	4	3	37
M4	3	3	3	4	3	4	2	4	3	29
M5	4	5	4	3	4	2	2	3	2	29

Los valores de la tabla son un ejemplo razonado que deberá ajustarse mediante consenso entre responsables de ciberseguridad, reguladores y analistas de datos.

4. Comentario cualitativo por métrica

M1 – Densidad de vulnerabilidades críticas expuestas

- Predictivo (3): Es moderadamente útil para anticipar incidentes, pero no distingue bien entre vulnerabilidades explotables y meramente teóricas. [web:1][web:16]
- Relevante (4) y Accionable (4): Muy comprensible y fácil de utilizar para priorizar campañas de parcheo y endurecimiento de superficie de ataque. [web:22]
- Genuino (3): Susceptible a cierto gaming (ocultar exposición, reclasificar activos), pero razonablemente honesto si la gestión de activos es madura.
- Significativo (4): Se explica fácil a políticos: “X % de los sistemas expuestos tienen agujeros graves”.
- Preciso (3): Depende de inventarios de activos y calidad de los escaneos; precisión media.
- Oportuno (4): Puede actualizarse con frecuencia (mensual, incluso semanal) si la infraestructura técnica está disponible.
- Independiente (3): Relativamente independiente, pero se apoya en procesos de gestión de activos gestionados por las mismas entidades que se miden.
- Rentable (4): Si ya existen escaneos y CMDB, el coste marginal es bajo.

M2 – Tiempo medio de mitigación de vulnerabilidades explotadas activamente

- Predictivo (5): Una ventana de exposición larga ante vulnerabilidades explotadas es una señal muy fuerte de futuros incidentes graves. [web:1][web:7][web:13]
- Relevante (5) y Accionable (5): Directamente conectada con obligaciones de diligencia y expectativas regulatorias; mejora tiempos de respuesta. [web:7][web:13]
- Genuino (4): Difícil de maquillar sin dejar huella, aunque existen tentaciones de “ajustar fechas”.
- Significativo (4): Fácil de entender: “tardamos X días en cerrar puertas que los atacantes ya están usando”.
- Preciso (3): Requiere buena gestión de tiempos de detección, notificación y cierre; la precisión puede sufrir en entornos complejos.
- Oportuno (3): Supone consolidar datos de varias fuentes; razonable trimestralmente.
- Independiente (4): Puede calcularse de forma centralizada, cruzando EUVD, CSIRTs y datos de remediación. [web:7][web:13]
- Rentable (3): Tiene cierto coste de integración de datos, pero su valor estratégico compensa.

M3 – Proporción de vulnerabilidades críticas en servicios esenciales sin mitigación en plazo

- Predictivo (5): Directamente asociada al riesgo de interrupciones en servicios esenciales y cumplimientos regulatorios. [web:7][web:10][web:12]
- Relevante (5) y Accionable (5): Perfecta para priorizar inversiones, auditorías y refuerzos en infraestructuras críticas.
- Genuino (4): Difícil de manipular sin colisión con auditorías y supervisores sectoriales.
- Significativo (5): Traduce el riesgo técnico a un mensaje muy claro: “tenemos X bombas de relojería sin desactivar en servicios esenciales”.
- Preciso (3): Depende de buena clasificación de servicios esenciales, scoring Environmental coherente y definición de “plazo”. [web:1][web:22]
- Oportuno (3): Datos más estables; actualización trimestral o semestral.
- Independiente (4): Puede ser calculada por entidades supervisoras a partir de reporting de operadores.
- Rentable (3): Requiere marcos de reporting, pero se apoya en obligaciones ya existentes (NIS2, sectoriales). [web:7][web:13]

M4 – Índice de cobertura de evaluación CVSS v4.0

- Predictivo (3): Más que predecir, mide capacidad de observación; su efecto predictivo es indirecto.
- Relevante (3): Importante para madurez de medición, menos inmediato para decisores.
- Accionable (3): Sugiere invertir en capacidades de scoring, pero sin acciones inmediatas sobre el riesgo. [web:28]
- Genuino (4): Difícil de maquillar si se cruzan fuentes independientes (EUVD, bases internas). [web:13]
- Significativo (3): Se puede explicar, pero puede parecer un KPI “de técnicos para técnicos”.
- Preciso (4): Fácil de contar: o hay scoring v4.0 completo o no lo hay. [web:1]
- Oportuno (2): Cambia lentamente; anual o semestral.
- Independiente (4): Puede calcularse sin depender de decisiones coyunturales de negocio.
- Rentable (3): Coste bajo si hay integración razonable de fuentes.

M5 – Índice de alineamiento regulatorio NIS2–CVSS

- Predictivo (4): Mayor alineamiento suele correlacionar con mejor gestión del riesgo y menor exposición a sanciones. [web:7][web:13]
- Relevante (5): Directamente vinculado a capacidad de cumplimiento y reporting a autoridades.
- Accionable (4): Permite priorizar sectores o entidades con baja trazabilidad CVSS–incidente.
- Genuino (3): Existe riesgo de reporting complaciente si no se audita.
- Significativo (4): Muy comunicable a nivel regulator (“X % de incidentes están trazados a métricas CVSS sólidas”).
- Preciso (2): Depende de definiciones y modelos de datos; potencial de ambigüedad.
- Oportuno (2): Suele actualizarse en ciclos largos de reporting (anual).
- Independiente (3): Depende parcialmente de cómo se diseñen los procesos de notificación.
- Rentable (2): Requiere ajustes en sistemas de reporting y puede ser costoso para operadores más pequeños.

5. Uso de la matriz PRAGMATIC

La matriz sirve para:

- Priorizar qué métricas deben entrar en el cuadro de mando nacional.
- Identificar métricas que requieren rediseño o simplificación.
- Justificar, frente a órganos de gobierno, por qué se adoptan unas métricas y no otras.

La matriz puede exportarse a Excel para facilitar cálculos, ponderaciones y visualización.